

AWS API Gateway Resource Policy

To Begin with the Lab

Summary of the Lab

In this lab, **API Gateway Resource Policy** was configured as a security layer to control from where an API can be accessed. The example used the existing **REST API** from the earlier lab and applied a JSON-based resource policy that allowed access only from one specific IP address. After the policy was added, the API was redeployed so the change would take effect. When the request was tested from **Postman**, access was denied with a **403 Forbidden** error because the client IP did not match the allowed IP in the policy. After removing the restriction and deploying again, the same request worked successfully and the record was created in **DynamoDB**.

Understanding API Gateway Resource Policy

An **API Gateway Resource Policy** is a JSON security rule that controls who can reach your API and from where it can be accessed. It exists so you can restrict access by IP address, VPC, AWS account, or organization instead of allowing every internet client to call the API. This is different from an API key or usage plan because resource policies act earlier in the request flow, before the request reaches Lambda or other backend services. It is not used for authentication with usernames or passwords; it is used to control network- or account-level access to the API itself.

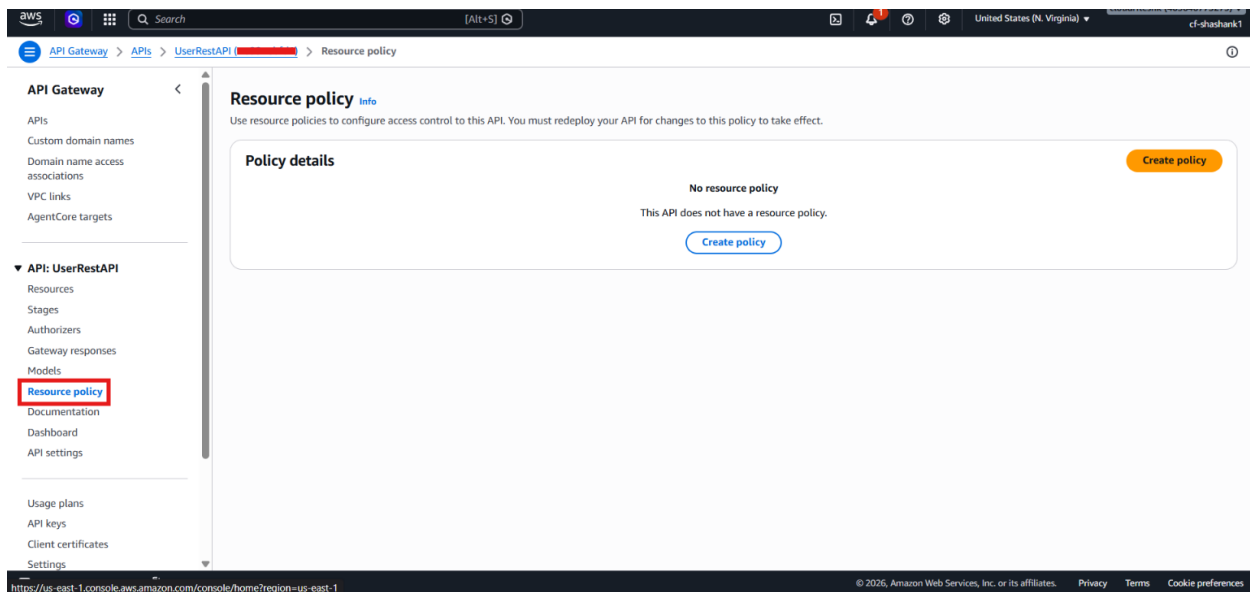
Example:

A company wants its API to be callable only from the office network. The resource policy allows only the office public IP and blocks all other IPs. When a request comes from another location, API Gateway denies it immediately with **403 Forbidden** before the request reaches Lambda.

Lab Steps

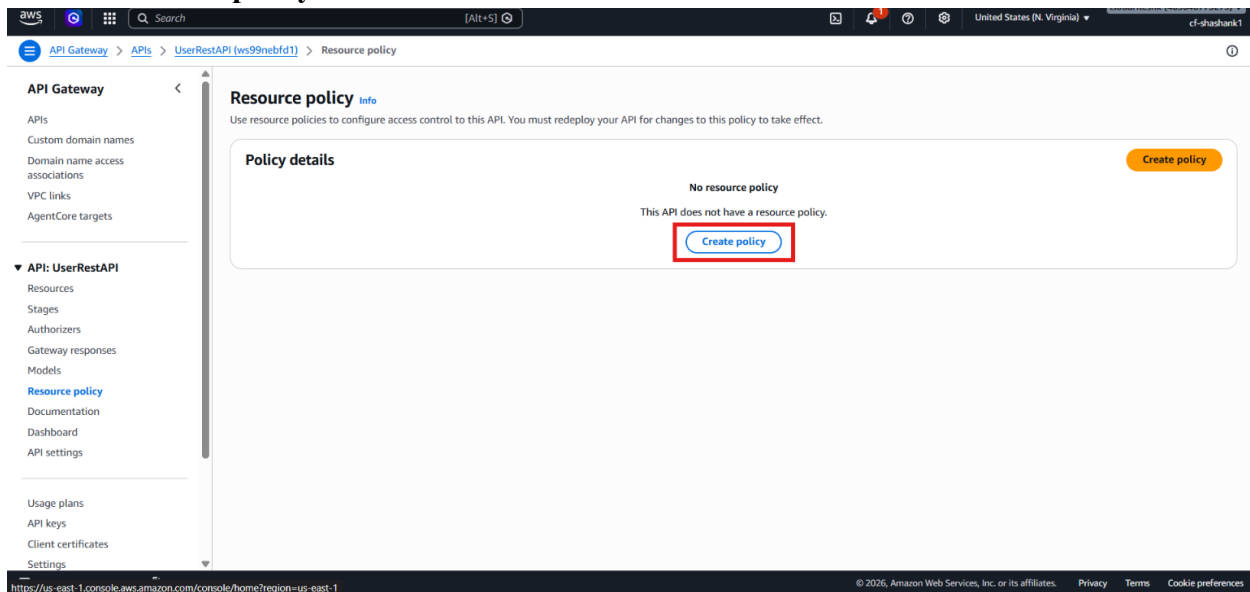
Step 1 – Open the REST API

- Sign in to the AWS Management Console.
- Open **API Gateway**.
- Select the existing **REST API** used in the earlier lab.
- Open the **Resource Policy** section.



Step 2 – Prepare the Resource Policy

- Click **Create policy**.

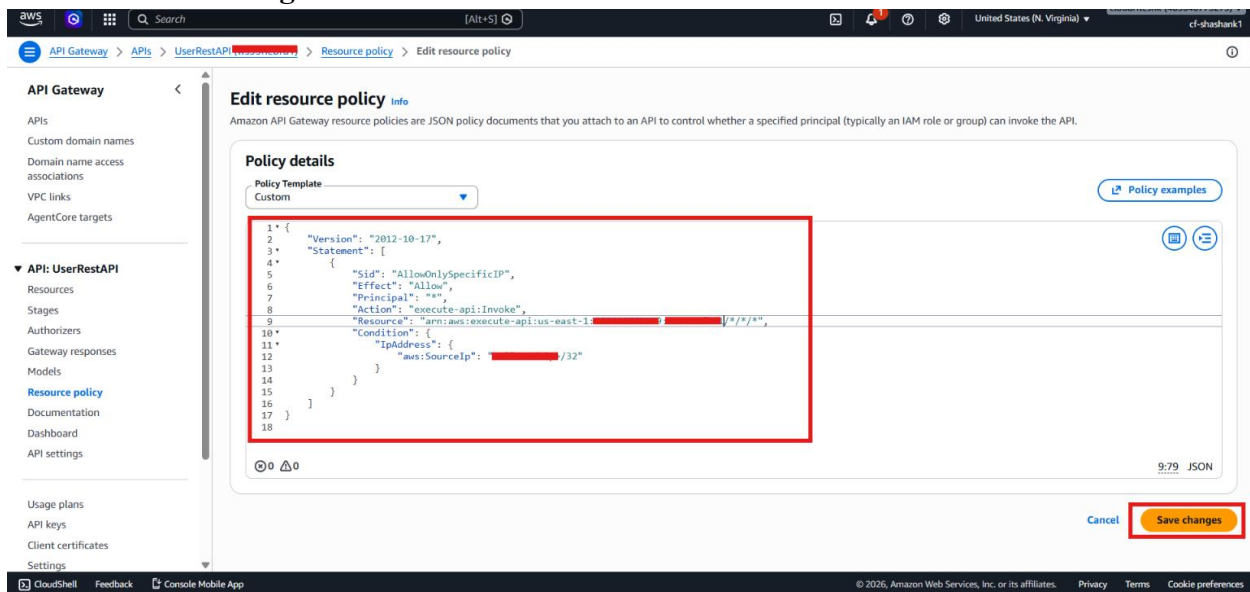


- Use the provided JSON policy.
- Update the policy with your own:
 - AWS Region
 - AWS Account ID
 - API ID
- Make sure the API ARN is correct.
- Copy the final policy into the editor.

Step 3 – Save the Policy

- Paste the policy into **Resource Policy**.

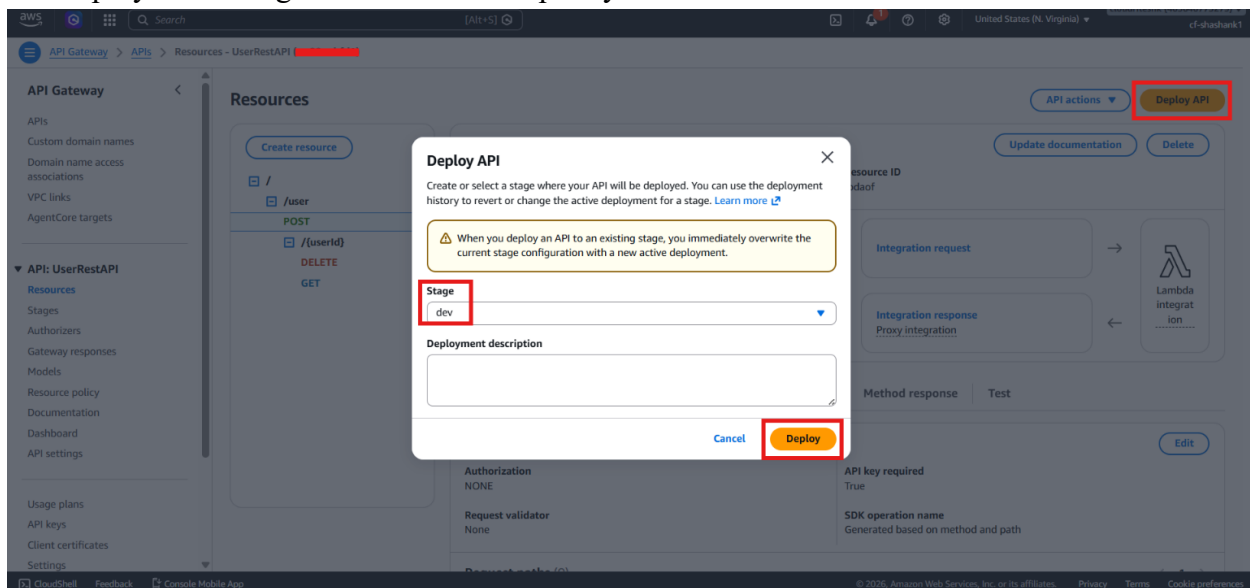
- Click **Save Changes**.



- Confirm that the policy is now attached to the API.

Step 4 – Deploy the API Again

- Open the API.
- Click **Deploy API**.
- Select the existing stage, such as **dev**.
- Deploy the API again so the resource policy takes effect.

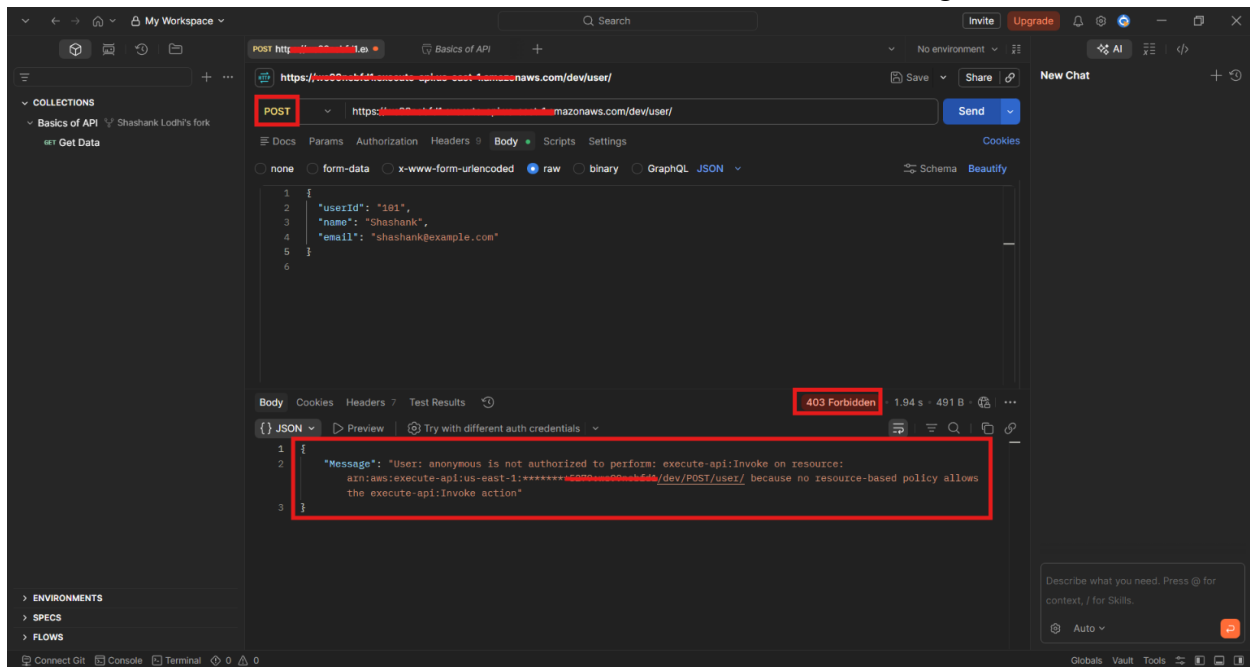


- Wait for the deployment to complete.

Step 5 – Test the Restricted API

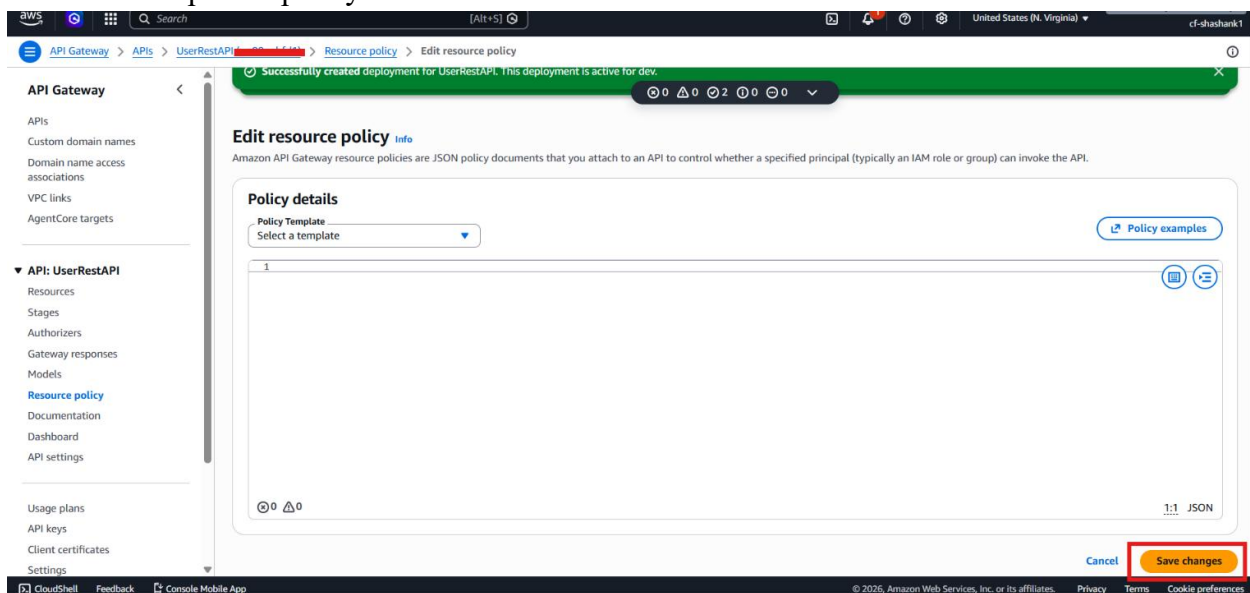
- Open **Postman**.
- Send the same POST /user request used in the REST API lab.

- Use the invoke URL of the deployed stage.
- Observe that the request is rejected.
- Confirm that the error is **403 Forbidden** with an unauthorized message.



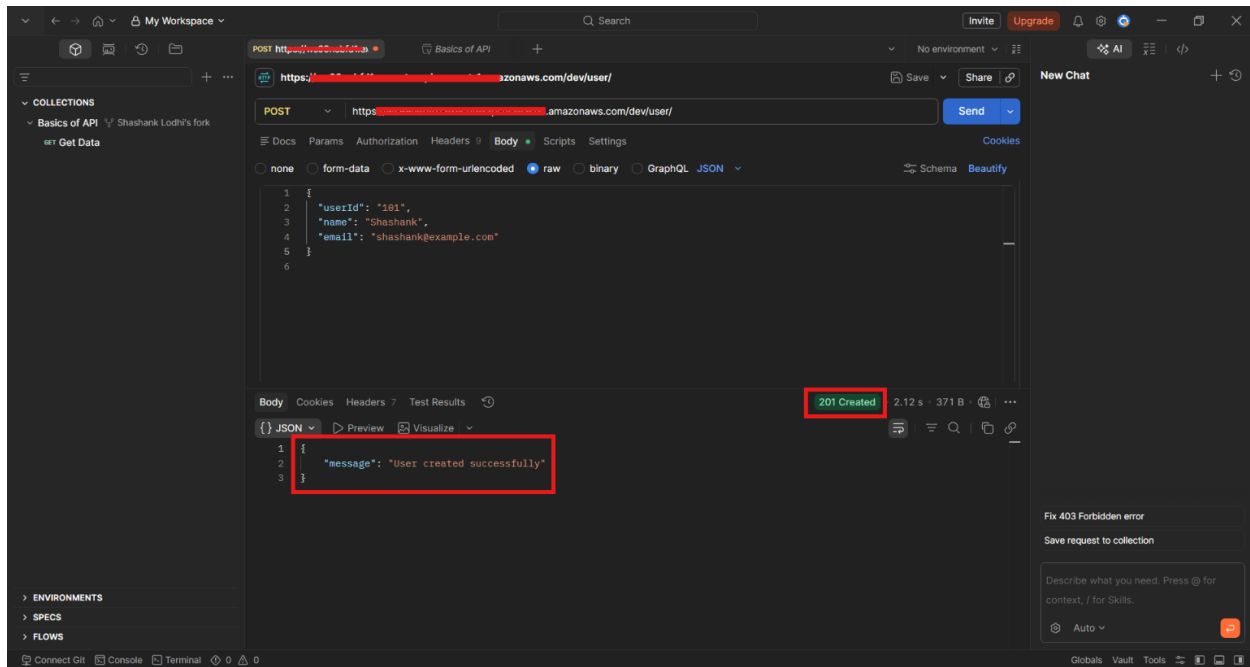
Step 6 – Remove the Restriction and Retest

- Return to the **Resource Policy** section.
- Remove the IP restriction from the policy.
- Save the updated policy.



- Deploy the API again.
- Wait for the deployment to finish.
- Retest the same POST /user request in **Postman**.

- Confirm that the request now succeeds and the user record is created.



Verification

- An **API Gateway Resource Policy** was created successfully.
- The policy restricted access based on IP address.
- The API was redeployed after the policy change.
- Requests from unauthorized IPs were blocked with **403 Forbidden**.
- After removing the policy restriction, the request succeeded again.
- The lab confirmed that resource policies control where an API can be accessed from.